

Assessment de arquitectura productiva

Versión corregida y consolidada de la arquitectura, funcionalidad, aislamiento de clientes y ruta de implementación cloud.

Propósito

Entregar una referencia única y veraz para el equipo técnico, socios e integradores. Distingue capacidades ya implementadas en el repositorio de configuraciones que deben activarse en AWS antes de operar con clientes reales.

Elemento	Estado de referencia
Producto	Nexo Klar Cloud v7.7.0
Fecha	11 de agosto de 2026
Código oficial	Repositorio GitHub y carpeta oficial del proyecto
Cobertura	Frontend público y privado, API, datos, seguridad, AWS, clientes e integraciones
Clasificación	Uso interno · evaluación técnica y preparación productiva

Conclusión ejecutiva. La base de producto incorpora backend multiempresa, RLS, sesiones seguras, auditoría, control de versiones, almacenamiento S3 preparado y validaciones automatizadas. La salida a producción requiere completar y probar infraestructura AWS, integraciones reales, observabilidad y continuidad.

1. Resumen ejecutivo y correcciones

El assessment v4 contiene supuestos que no representan el repositorio actual. Esta versión reemplaza esos supuestos por el estado verificable del código y una arquitectura objetivo razonable para AWS.

Tema	Assessment anterior	Arquitectura real / corrección
Frontend	React 18, Vite y Tailwind	HTML, CSS y JavaScript modular; public/index.html y public/cloud-client.js son la aplicación servida.
Backend	Node.js 22	Node.js 20 o superior con Express 5.
Contraseñas	bcrypt	script con salt único, de acuerdo con la implementación actual.
Aislamiento	RLS no activo	RLS está habilitado y FORCE ROW LEVEL SECURITY protege las tablas críticas.
Persistencia	27 tablas / 19 migraciones	PostgreSQL con 21 migraciones versionadas , entidades normalizadas y estado modular.
Base de datos	Aurora Serverless v2 como hecho	Soporta PostgreSQL 15+ . RDS PostgreSQL es la base recomendada; Aurora es alternativa opcional.
Cifrado S3	Sin SSE configurado	S3 privado, versionado y cifrado son requisito de producción; dependen de la cuenta AWS.

Regla de lectura: “Implementado” significa que existe en código y pruebas. “Por configurar” implica una cuenta, credencial, servicio o política externa que debe contratarse, habilitarse y validarse antes de la operación productiva.

2. Alcance funcional y relación de datos

Nexo Klar centraliza la operación comercial, laboral, documental y de terreno. Cada registro se relaciona con la empresa usuaria y puede vincularse a cliente, contrato, orden de servicio, persona, recurso y evidencia.

Flujo operativo

- Empresa (tenant)
- ■ ■ ■ Prospectos y oportunidades
- ■ ■ ■ Cliente
- ■ ■ ■ Contrato / firma / anexo
- ■ ■ ■ Orden de servicio
- ■ ■ ■ Personas y asignaciones
- ■ ■ ■ Vehículos, activos, EPP, alojamiento y turnos
- ■ ■ ■ Documentos, cursos, exámenes, credenciales y habilitación
- ■ ■ ■ Libro de obra, incidentes, CAPA, costos y reportes
- ■ ■ ■ Terceros y subcontratos
- ■ ■ ■ Gobierno: usuarios, permisos, auditoría, privacidad y configuración

Capa	Módulos y uso real
Relación comercial	Prospectos, clientes, contratos, firmas, órdenes de servicio y seguimiento de condiciones.
Capital humano	Personas fijas, por proyecto o disponibles; turnos, asistencia, EPP, formación, exámenes, salud y restricciones.
Operación	Convocatorias, alojamiento, vehículos, activos, inventario, terceros, ejecución y libro de obra.
Cumplimiento	Documentación corporativa, habilitación de cliente, auditoría, incidentes, no conformidades y acciones.
Gestión	Paneles, alertas, reportes, analítica, bitácora de cambios, privacidad, permisos y catálogos por empresa.

3. Arquitectura lógica de referencia

La plataforma debe operar con un único origen HTTPS. El navegador no determina el tenant: la API obtiene usuario, rol y empresa desde la sesión segura, y PostgreSQL aplica el aislamiento de datos.

Ruta de solicitud Usuario autorizado → HTTPS / WAF opcional → ALB → ECS Fargate (Express) → transacción con contexto de tenant → PostgreSQL RDS con RLS. Los archivos viajan a S3 privado por la API y solo se entregan mediante autorización y URL firmada.

Capa	Tecnología / responsabilidad	Estado
Interfaz	Sitio público y aplicación privada HTML/CSS/JS. Cliente cloud para consumir API.	Implementado
API	Express, validación, autorización por rol, CSRF, control de concurrencia y rutas por dominio.	Implementado
Datos	PostgreSQL 15+, migraciones, RLS, restricciones, módulos y entidades normalizadas.	Implementado / requiere instancia
Archivos	Metadatos, hash, tamaño máximo, antivirus previsto; S3 privado en producción.	Preparado / requiere S3 y proveedor AV
Integraciones	SMTP, WhatsApp Cloud API, firma, OCR/IA, ERP y acreditación mediante conectores y eventos.	Preparado / requiere proveedores

No usar producción desde file://. El HTML independiente sirve para demostración local. La operación productiva debe ser servida por la API, con PostgreSQL como fuente autoritativa y S3 como almacenamiento documental.

4. Separación completa por empresa

Nexo Klar utiliza un modelo multi-tenant de base compartida y filas separadas por **tenant_id**. Empresa A, B y N no deben compartir vistas, archivos, catálogos, usuarios ni configuraciones, aun cuando utilicen la misma infraestructura.

Control	Cómo se aplica	Resultado esperado
Sesión	La cookie HttpOnly identifica una sesión validada; el backend resuelve tenant, usuario y rol.	El navegador no puede elegir otra empresa.
Autorización	Cada endpoint verifica rol y pertenencia antes de leer o escribir.	Permisos acotados a función y tenant.
Base de datos	La transacción establece app.current_tenant_id; RLS y FORCE RLS filtran tablas críticas.	Defensa ante errores de filtro en aplicación.
Datos y archivos	IDs, RUT, vínculos y claves se validan por empresa. S3 usa prefijos por tenant y acceso autorizado.	No se mezclan documentos ni entidades.
Configuración	tenant_settings, catálogos e integraciones se mantienen por empresa; secretos se cifran.	Parametrización independiente.
Auditoría	Eventos con usuario, fecha, entidad, resumen y contexto de tenant.	Trazabilidad de cambios y soporte.

Prueba obligatoria de aceptación: crear tres empresas de prueba, cargar datos equivalentes y comprobar que una no puede buscar, descargar, exportar ni inferir información de las otras. Repetir en cada liberación mayor.

5. Datos, integridad y trazabilidad

El sistema combina colecciones funcionales versionadas para compatibilidad con tablas normalizadas para procesos críticos, integraciones, reportes y evolución. La dirección correcta es aumentar las rutas que usan entidades normalizadas sin romper la experiencia vigente.

Dominio	Entidades principales	Control relevante
Identidad	tenants, app_users, user_sessions	Roles, MFA, sesiones revocables, bloqueo y aprobación de cuentas.
Comercial	clientes/mines, commercial_contracts, projects, asignaciones	Vínculos por tenant y fechas coherentes.
Personas	workers, documentos, cursos, exámenes, estado operativo	RUT único por empresa, estado habilitado/restringido, matriz de requisitos.
Recursos	vehículos, hoteles, EPP, inventario, movimientos y mantenimiento	Asignación, disponibilidad, costo y vida útil.
Cumplimiento	requisitos, revisiones, file_objects, habilitación, auditoría	Vigencias, evidencias, responsables y bloqueo automático.
Gobierno	audit_log, historial, privacidad, consentimientos y eventos	Historial append-only y trazabilidad por entidad.

Integridad ya considerada: RUT único por trabajador en la empresa, identificadores únicos, referencias entre entidades, coherencia de fechas, sanitización de HTML ejecutable, bloqueo de Base64 y control optimista de versión por módulo.

6. Seguridad, identidad y datos personales

Área	Control actual en repositorio	Cierre productivo requerido
Contraseñas	script con salt único.	Política de longitud, control de credenciales filtradas y entrenamiento de soporte.
Sesiones	Token con hash, cookie HttpOnly/Secure/SameSite=Strict y revocación.	HTTPS real, expiración revisada y cierre global ante incidente.
MFA	Validación de entorno exige MFA_REQUIRED=true en producción.	TOTP, enrolamiento, recuperación segura y prueba de pérdida de dispositivo.
CSRF / origen	Protecciones de origen y CSRF a nivel de API.	CSP estricta sin unsafe-inline donde sea viable y pruebas OWASP.
Archivos	Hash, límite de 25 MB, estado antivirus y metadatos.	Servicio AV real, cuarentena, reescaneo y política de descarga.
Datos sensibles	RLS y secretos de integración cifrados AES-256-GCM.	Clasificación, retención, derechos de titulares y cifrado adicional donde corresponda.

La Ley 21.719 exige gobierno real, no solo una pantalla de privacidad. Antes del lanzamiento se deben aprobar: inventario de tratamientos, base jurídica, periodos de conservación, respuesta a derechos de titulares, protocolo de incidentes y responsables internos.

7. Documentos, archivos e integraciones

El motor documental está diseñado para mantener revisión humana final. Las integraciones agregan evidencia y puntaje, pero no deben habilitar por sí solas a una persona, vehículo o empresa sin la validación responsable.

Componente	Función	Patrón de integración
S3 privado	Contratos, certificados, fotografías, evidencias y documentos de cumplimiento.	Carga vía API, metadatos/file_objects, prefijo de tenant, URL firmada, versionado y lifecycle.
Antivirus	Evita adjuntos maliciosos.	Archivo en cuarentena; se publica tras respuesta limpia del proveedor.
OCR / IA documental	Extrae fechas, emisor, nombre, RUT, QR y señales de consistencia.	Webhook/REST asíncrono, resultado guardado, score explicable y revisión humana.
Firma electrónica	Contrato, anexo, libro de obra y actas.	Crear sobre, enviar por canal autorizado, recibir webhook firmado y mantener versión/evidencia.
Correo / WhatsApp	Convocatorias, vencimientos y solicitudes de firma.	Plantillas, consentimiento, historial de entrega, error y respuesta.
ERP / acreditación	Órdenes, costos, facturación y habilitación cuando exista API oficial.	Eventos idempotentes, trazables, con reintentos y sin automatizar portales sin autorización.

8. Diseño AWS recomendado

La infraestructura debe desplegarse en una cuenta AWS de producción separada de desarrollo y prueba. RDS PostgreSQL es la alternativa base; Aurora PostgreSQL es una decisión opcional de capacidad y costo, no un requisito técnico.

Arquitectura objetivo

Usuarios

- DNS + ACM + HTTPS
- Application Load Balancer (subredes públicas)
- ECS Fargate / Express (subredes privadas, 2 AZ)
- RDS PostgreSQL 15+ privado (Multi-AZ)
- S3 privado (documentos, versionado, SSE)
- Secrets Manager
- CloudWatch Logs / métricas / alarmas
- NAT o endpoints privados para integraciones y AWS

GitHub Actions → ECR → tarea de migración controlada → ECS

Servicio	Configuración mínima de producción
Red	VPC, subredes públicas para ALB y privadas para ECS/RDS; SG de mínimo privilegio; dos zonas de disponibilidad.
ECS	Dos tareas iniciales, healthcheck /api/health, readiness /api/ready, escalamiento por CPU/memoria y despliegue progresivo.
RDS	PostgreSQL 15+, sin acceso público, cifrado, backups automáticos, restauración probada y conexión solo desde ECS.
S3	Bloqueo público, SSE-KMS o SSE-S3, versionado, lifecycle, task role y monitoreo de acceso.
Secretos	Secrets Manager para DATABASE_URL, TENANT_SECRET_KEY, tokens y claves; rotación y acceso IAM por rol.
Perímetro	ACM, HTTPS, WAF recomendado, rate limiting, registros de ALB y cabeceras seguras.

9. Despliegue, calidad y continuidad

Etapa	Secuencia recomendada	Evidencia de salida
1. Desarrollo	Cambios en rama, revisión y pruebas automatizadas.	Tests OK, sintaxis y revisión funcional.
2. Preproducción	Misma arquitectura con datos sintéticos; migraciones y smoke tests.	Aprobación funcional y prueba de aislamiento A/B/C.
3. Imagen	Build Docker, escaneo de dependencias/imagen, publicación en ECR por commit.	Tag inmutable y reporte de build.
4. Migración	Tarea puntual antes del despliegue; nunca desde todas las réplicas.	schema_migrations actualizado y respaldo previo.
5. Producción	Rolling o blue/green según madurez; health/readiness y rollback definido.	Versión desplegada, métricas normales y smoke test.
6. Continuidad	Backups, restauración trimestral, runbook, RPO/RTO y simulacro.	Acta de restauración y acciones de mejora.

La arquitectura queda lista para automatizarse, no desplegada por sí sola. El repositorio prepara Docker, ECS, variables, migraciones y pipeline base. Se deben crear cuenta, IAM, DNS, certificados, servicios, secretos, alarmas y pruebas de recuperación con credenciales reales.

10. Observabilidad, soporte y gobierno

Dominio	Implementar y operar
Disponibilidad	Alarmas por 5xx, healthcheck fallido, tareas ECS bajo mínimo, latencia ALB y errores de autenticación.
Base de datos	Métricas de conexiones, CPU, almacenamiento, slow queries, backup exitoso y replicación/Multi-AZ.
Archivos	Alertas por antivirus fallido, archivos en cuarentena, errores de S3 y URLs firmadas denegadas.
Aplicación	Logs estructurados con request_id, tenant_id pseudonimizado, endpoint, tiempo, código y error; sin secretos ni documentos.
Auditoría	Revisión periódica de cambios sensibles, permisos, exportaciones, restauraciones y restablecimientos.
Soporte	Tickets por tenant, prioridad, dueño, SLA, bitácora y comunicación con cliente.

Definir responsables: dueño de plataforma, responsable de seguridad, responsable de datos personales, soporte de primer nivel y contacto de incidente. La herramienta registra información; la operación requiere personas y un procedimiento activo.

11. Estado de preparación productiva

Área	Estado del repositorio	Condición para declarar producción
Aplicación y módulos	Base funcional amplia: comercial, personas, operación, cumplimiento, activos, libro de obra y reportes.	QA de flujos críticos por plan y autorización de negocio.
Multiempresa	tenant_id, RLS, roles, configuración por tenant y pruebas automatizadas.	Prueba E2E con tres clientes y datos reales controlados.
Seguridad	Sesiones seguras, MFA exigible, CSRF, validaciones, auditoría y secretos cifrables.	MFA, pentest, CSP revisada, WAF y procedimiento de incidente.
Datos / archivos	Migraciones, reglas de integridad y conectores S3/antivirus preparados.	RDS y S3 reales, cifrado, AV, backups/restauración y lifecycle.
Integraciones	Rutas y eventos para SMTP, WhatsApp, firma, OCR, ERP y acreditación.	Contratos, credenciales, sandbox, webhooks y monitoreo validados.
Infraestructura	Docker, Compose, plantilla ECS, variables y pipeline base disponibles.	AWS con IAM, red, dominio, alarmas, staging y runbook probado.

Dictamen

Preparada para implementación productiva controlada. La plataforma no debe declararse operativa para clientes reales hasta completar las configuraciones externas y las pruebas de seguridad, recuperación, integraciones y aislamiento descritas en este documento.

12. Backlog priorizado para la salida

Prioridad	Iniciativa	Resultado verificable
P0	Crear ambientes dev, staging y producción separados; CI obligatorio antes del despliegue.	No hay cambios directos a producción sin pruebas y aprobación.
P0	Desplegar RDS privado, S3 cifrado/versionado, Secrets Manager, ECS Multi-AZ, HTTPS y MFA.	Arquitectura base operando con acceso mínimo y datos separados.
P0	Configurar antivirus, backups, restauración de ensayo, CloudWatch y alertas de caída.	Evidencia de restauración y notificación de incidente.
P0	Pentest externo, revisión IAM, prueba de aislamiento y validación Ley 21.719.	Informe de seguridad y plan de remediación aceptado.
P1	Conectar firma, OCR, QR, emisor y score documental; mantener revisión humana final.	Flujo documental con proveedor real y trazabilidad de decisión.
P1	Normalizar progresivamente entidades críticas, reporting y API pública por dominio.	Consultas, BI e integraciones confiables y escalables.
P1	Definir RPO/RTO, DRP, ownership de alertas y mesa de soporte.	Runbook, simulacro y responsables activos.
P2	Autoescalado fino, WAF, rotación de secretos y evaluación de Aurora si la carga lo exige.	Optimización por métrica, costo y nivel de servicio.

Siguiente hito sugerido: sesión de arquitectura con AWS e integrador para completar checklist de preproducción, asignar responsables, levantar la cuenta cloud y ejecutar el primer despliegue en staging antes de habilitar clientes comerciales.